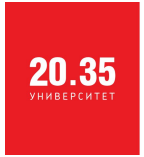
SQL-инъекции уязвимость и защита

Python в задачах информационной безопасности



В этом уроке

- SQL-инъекции: что это, типы атак (In-Band, Blind, UNION).
- Как злоумышленники извлекают данные через UNION-инъекции.
- Параметризованные запросы, экранирование ввода, ограничение прав доступа.
- Эксплуатация уязвимости в SQLite и реализация защиты в коде.

Практическое задание

Демонстрация уязвимости на SQLite (OR 1=1)

Создайте уязвимый скрипт на Python + SQLite, который проверяет логин и пароль. Покажите, как атакующий может обойти аутентификацию.

Практическое задание

Создание безопасного запроса (параметризация)

Исправьте уязвимый код из задачи 1, используя параметризованные запросы.

Практическое задание

UNION-инъекция в SQLite

Создайте таблицу products(id, name) и покажите, как злоумышленник может получить все данные из таблицы users, используя UNION.

Практическое задание

Слепая SQL-инъекция (Blind SQLi)

Создайте таблицу secrets(key, value) и покажите, как атакующий может угадать значение, анализируя задержки ответа.

Практическое задание

Фильтрация вводимых данных (белые списки)

Напишите функцию, которая проверяет, содержит ли ввод только буквы и цифры.

Практическое задание

Экранирование спецсимволов

Напишите функцию для экранирования кавычек в SQLite.

Практическое задание

Ограничение прав доступа в SQLite

Создайте пользователя БД с правами только на SELECT.

Практическое задание

Логирование SQL-инъекций

Настройте логирование SQL-запросов в Python (модуль logging).

Скринкаст

Итоги урока

- Научились распознавать уязвимые места в SQL-запросах.
- Освоили защиту через параметризованные запросы (например, cursor.execute(..., (login,))).
- Поняли, как предотвращать атаки с помощью экранирования спецсимволов и принципа минимальных привилегий.
- Применили знания на практике: создали уязвимый код и реализовали его защиту.